

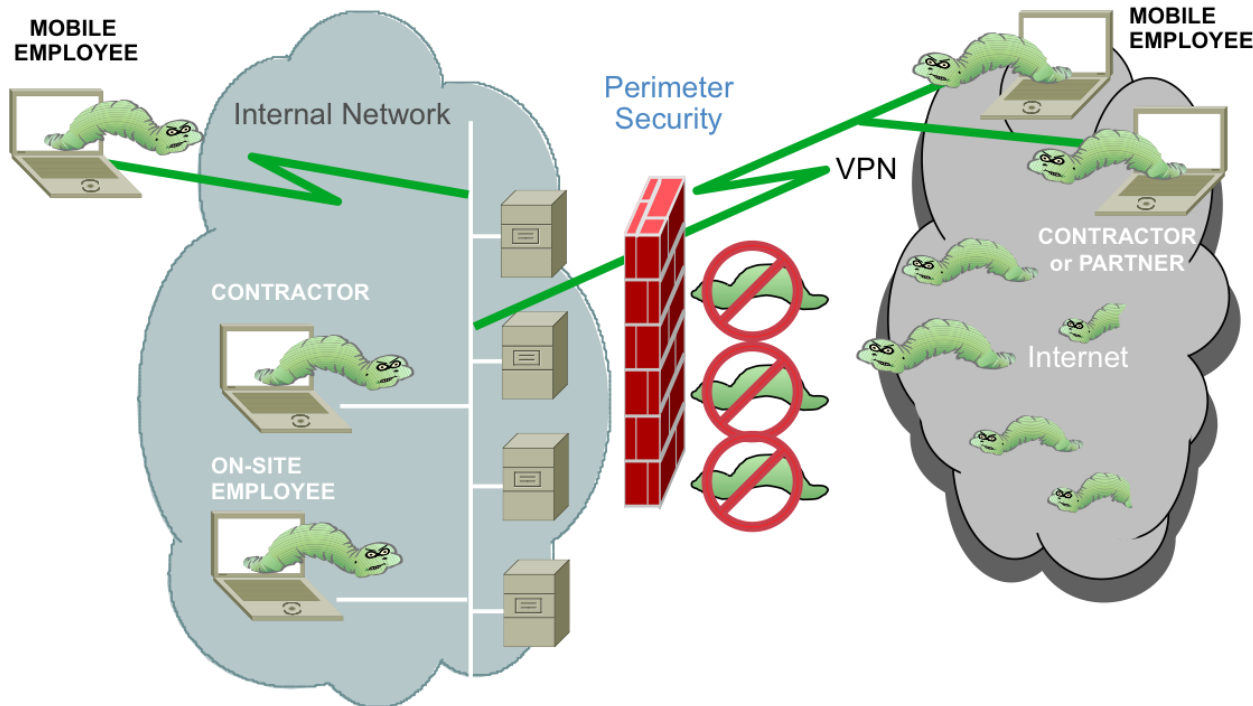
ЛЕКЦИЯ 11

Системи и средства за управление на контрола на достъп и трафика в мрежата

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Проблем – Как да защитим компютърната мрежа от своите собствени потребители?

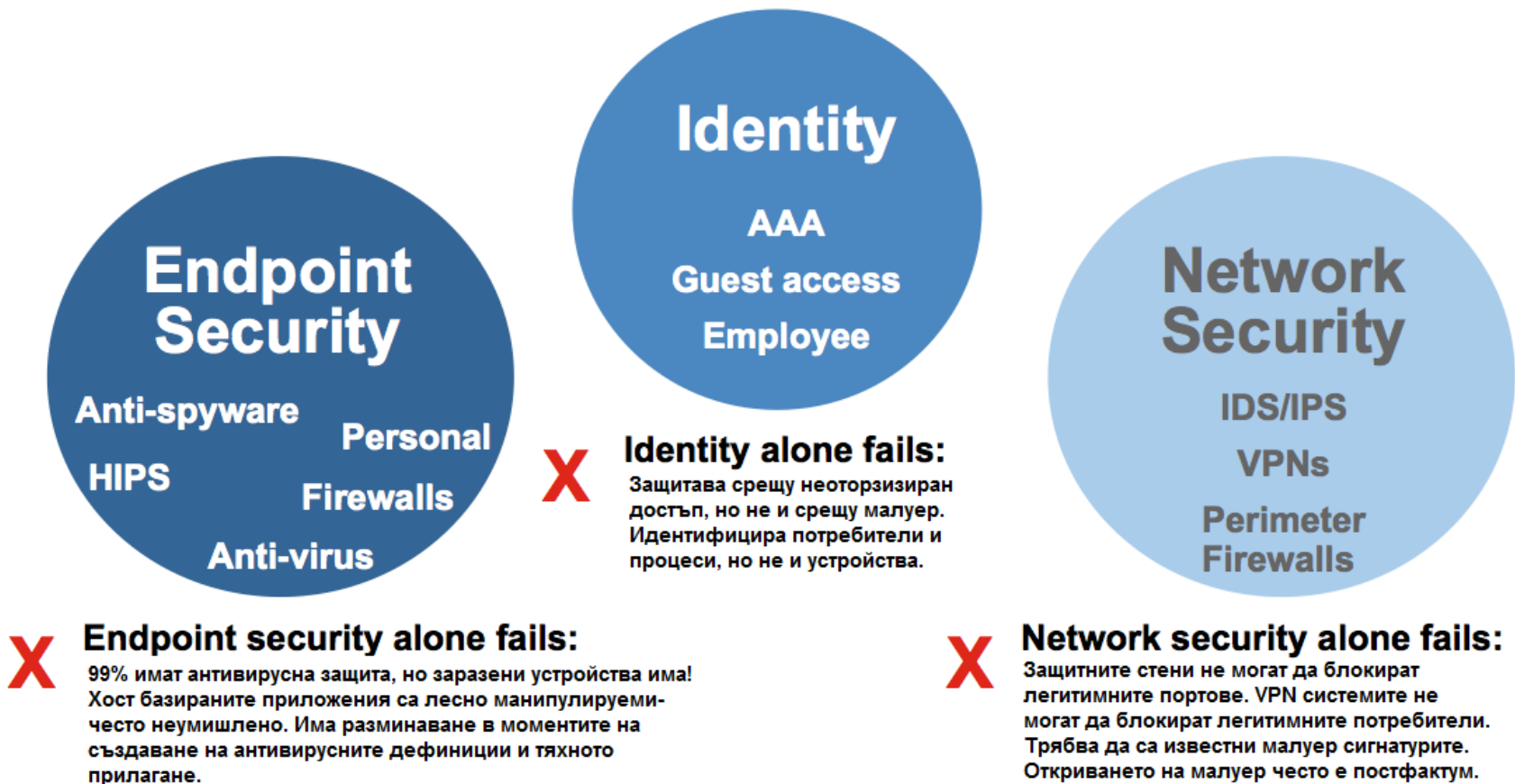


Вирусите, червеите и ботнетите често се разпространяват от жертви, които не подозират това. Тези жертви могат да бъдат собствените потребители на компютърната мрежа.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Проблем – Как да защитим компютърната мрежа от своите собствени потребители?



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Предимства и недостатъци на системите за Endpoint security

Предимства:

- Според Gartner те са продукти, които обединяват в едно антивирусна и anti-spyware защита, персонална защитна стена, контрол на приложенията и елементи на предотвратяване на проникванията
- Централизирано управление и налагане на политики на крайните устройства.
- Идентифицират устройствата, които не са с актуализирани дефиниции или версии на системния и приложен софтуер
- Наложените политики не могат да бъдат забранявани от потребителите

Недостатъци:

- Агентите на софтуера понижават производителността на устройствата и понякога потребителите могат да спрат сканирането

МРЕЖОВО АДМИНИСТРИРАНЕ

Предимства и недостатъци на системите за Identity management

Предимства:

- Намаляват риска даден акаунт да бъде компрометиран
- Осигуряват централизирано управление
- Приложими са за среден и голям бизнес

Недостатъци:

- Изискват перфектно спазване на политиката за сигурност
- В Ad Hoc среда не могат да гарантират, че служителите получават достъп само до приложенията, които са им необходими

МРЕЖОВО АДМИНИСТРИРАНЕ

Предимства и недостатъци на системите за Network security

Предимства:

- VLAN-ите разделят доверените устройства и тези, които не са в отделни мрежи и създават отделни бродкаст домейни за тях.
- Ограничава се възможността за разпространение на вируси и атаки към доверените устройства

Недостатъци:

- Няма начин да се ограничи свързване на недоверени устройства към портове на комутаторите, които са свързани към доверената мрежа
- Грешки в конфигурирането на устройствата може да предизвика достъп до важни ресурси
- Използването на различни подмрежи води до неефективно използване на IP адресите
- Комутаторите могат да бъдат уязвими на атаки MAC flooding, tagging, multicast brute force и др.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е решението?

- **Целта е изграждане на комплексно решение за Network Access Control (NAC)**
- NAC е решение за управление на свързването в компютърната мрежа, което използва набор от протоколи за дефиниране и прилагане на политика, дефинираща как се осигурява достъп до мрежови ресурси от устройства, в момента когато първоначално се опитват да получат достъп до мрежата;
- NAC е подход към сигурността на компютърните мрежи, който се опитва да обедини технологиите за защита на крайната точка (като антивирусна защита, предотвратяване на проникване до хоста и оценка на уязвимостта му), удостоверяване на потребители или системи и прилагане на мрежовата сигурност;
- NAC удостоверява потребителите, влизащи в мрежата, и определя до кои ресурси да получат достъп и какви действия могат да изпълнят;
- NAC проверява състоянието на компютъра или мобилното устройство на потребителя (крайните точки);

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е решението?

Целта е изграждане на комплексно решение за NAC



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е решението?

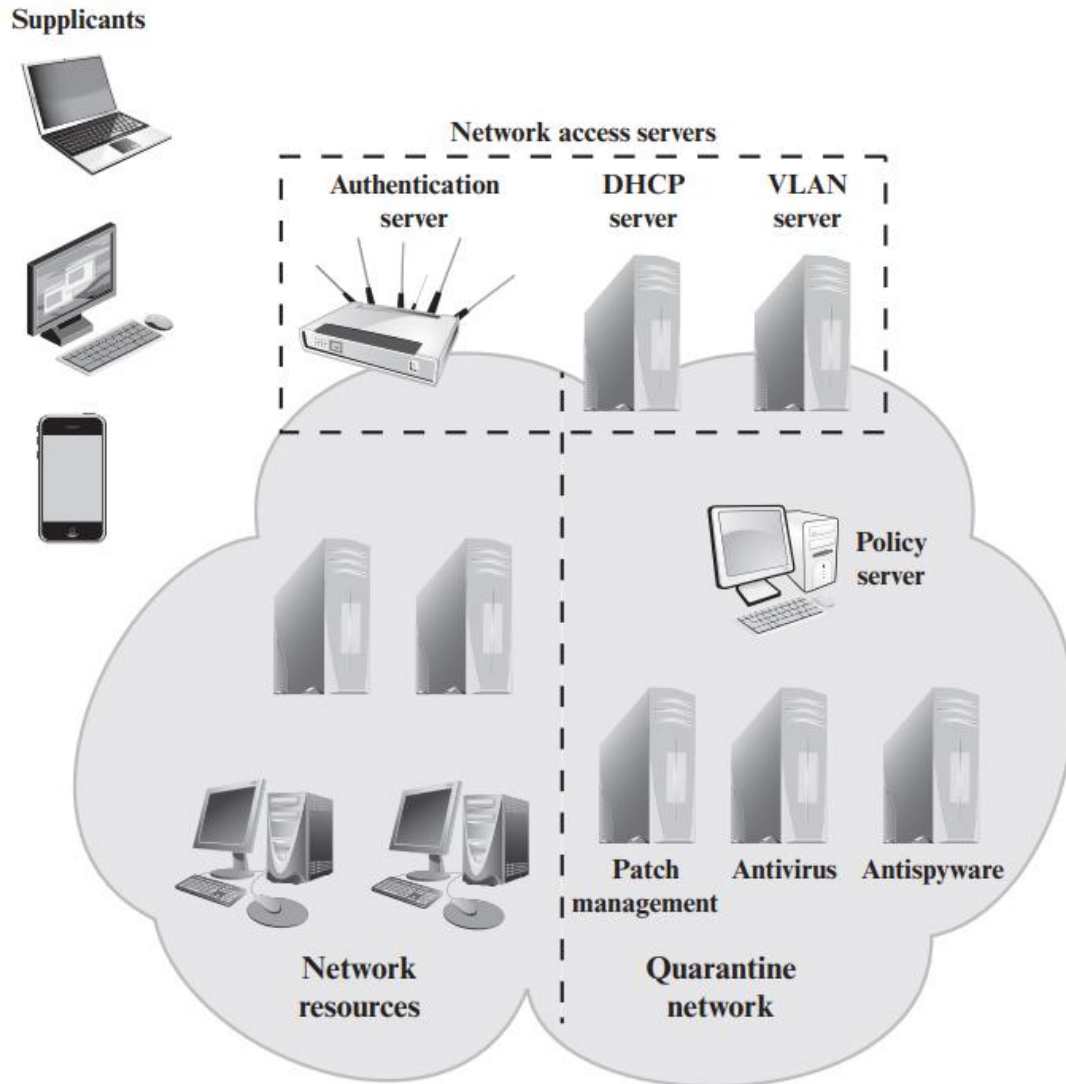
➤ Компоненти на NAC

- **Access Requestor (AR)** – клиент (запитващ), който се опитва да осъществи достъп до мрежата. Това е всяко устройство, което се управлява от NAC;
- **Policy server** - въз основа на дефинираната от организацията политика, сървърът на правилата определя какъв достъп трябва да бъде предоставен;
- **Network Access Server (NAS)** - нарича се още *media gateway*, сървър за отдалечен достъп (RAS) или сървър за прилагане на политики. NAS функционира като точка за контрол на достъпа за потребители в отдалечени локации, които се свързват с вътрешната мрежа на организацията.

МРЕЖОВО АДМИНИСТРИРАНЕ

Какво е решението?

➤ Компоненти на NAC



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

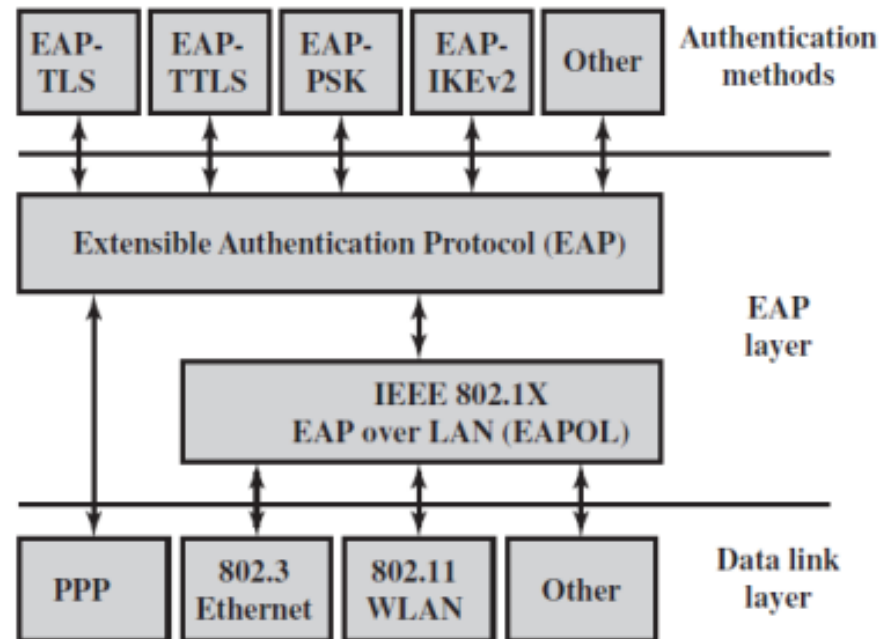
Методи за осигуряване на достъп до мрежата

- Методите за принудително изпълнение (**enforcement methods**) са действия, които се прилагат към ARs за регулиране на достъпа до корпоративната мрежа.
- **IEEE802.1X** – протокол на канален слой, който осигурява упълномощаване, преди на AR да му бъде присвоен IP адрес. IEEE 802.1X използва протокола EAP (Extensible Authentication Protocol за разширено удостоверяване) за осъществяване на процеса на удостоверяване.
- **Virtual local area networks (VLANs)** - корпоративната мрежа, състояща се от взаимосвързан набор от физически локални мрежи, се обособява логически в набор от виртуални локални мрежи. NAS решава към коя от VLAN мрежите ще присъедини AR;
- **Защитна стена (firewall)**: разрешава или отказва мрежов трафик между хост на организацията и външен потребител;
- **Управление на DHCP**: DHCP позволява динамично разпределение на IP адреси на хостове. DHCP сървърът управлява и определя IP адресите. По този начин, прилагането на NAS се извършва на мрежовия слой въз основа на принадлежността към подмрежа и присвояването на IP адрес.

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

- **Extensible Authentication Protocol (EAP) RFC 3748** – действа като платформа (framework) за управление на достъпа до мрежата и автентикация.
- ЕАР предоставя набор от протоколни съобщения, капсулиращи различни методи за удостоверяване, които да се използват за автентификация между клиент и сървър.
- ЕАР може да работи в различни устройства, на канално и мрежово нива, включително връзки от тип точка-точка, LAN и други мрежи и може да отговори на изискванията за удостоверяване на различните връзки и мрежи;



МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

- **EAP-TLS (EAP Transport Layer Security) RFC 5216:** определя как TLS протоколът може да бъде капсулиран в EAP съобщенията. Използва се протоколът за ръкостискане в TLS. Клиентът и сървърът се удостоверяват взаимно използвайки цифрови сертификати. Клиентът генерира ключ (pre-master key-произволно голямо число), който се криптира с публичния ключ на сървъра, и му го изпраща. Чрез този ключ се генерира сесийния ключ;
- **EAP-TTLS (EAP Tunneled TLS) RFC 5281 :** подобно на EAP-TLS, с разликата че само сървърът има сертификат, чрез който се удостоверява пред клиента. Както в EAP-TLS се създава сигурна връзка ("тунел") с договаряне на секретни ключове, но тази сигурна връзка се използва за да продължи процеса на автентикация като клиентът, а е възможно и сървърът, се удостоверяват отново използвайки някой от EAP методите или методи като PAP и CHAP;

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

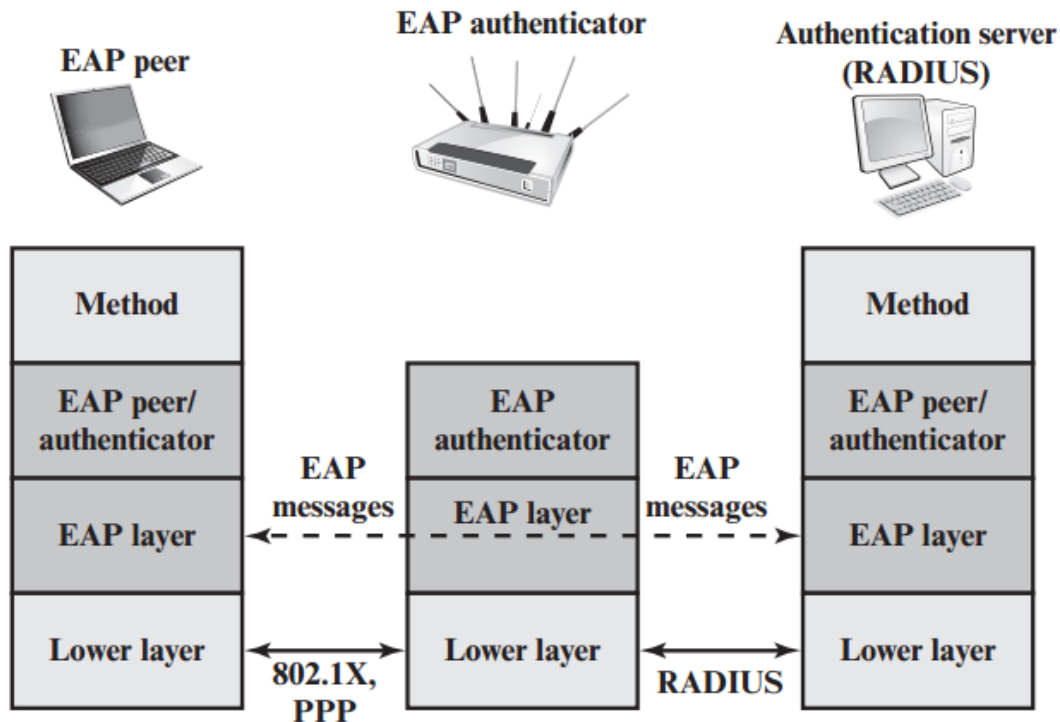
- **EAP-GPSK (EAP Generalized Pre-Shared Key) RFC 5433:** е EAP метод за взаимно удостоверяване и размяна на сесиен ключ, използвайки предварително споделен ключ (PSK). Следователно, този метод е ефективен по отношение на потоците от съобщения и изчислителните разходи, но изисква съществуването на предварително споделени ключове между всеки партньор и EAP сървър. Установяването на тези двойки тайни ключове е част от регистрацията на партньорите. Методът осигурява защитен комуникационен канал за да бъде взаимното удостоверяване успешно и за двете страни, и е предназначено за удостоверяване при комуникация в несигурни мрежи като IEEE 802.11. EAP-GPSK не изисква криптиране с публичен ключ. Обменът на съобщения по метода на EAP протокола се осъществява с минимум четири съобщения.;
- **EAP-IKEv2 (RFC 5106):** базиран на версия 2 на протокола Internet Key Exchange (IKEv2). Той поддържа взаимно удостоверяване и създаване на сесийни ключове чрез различни методи;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Обмен на съобщения при EAP (RFC 3748)

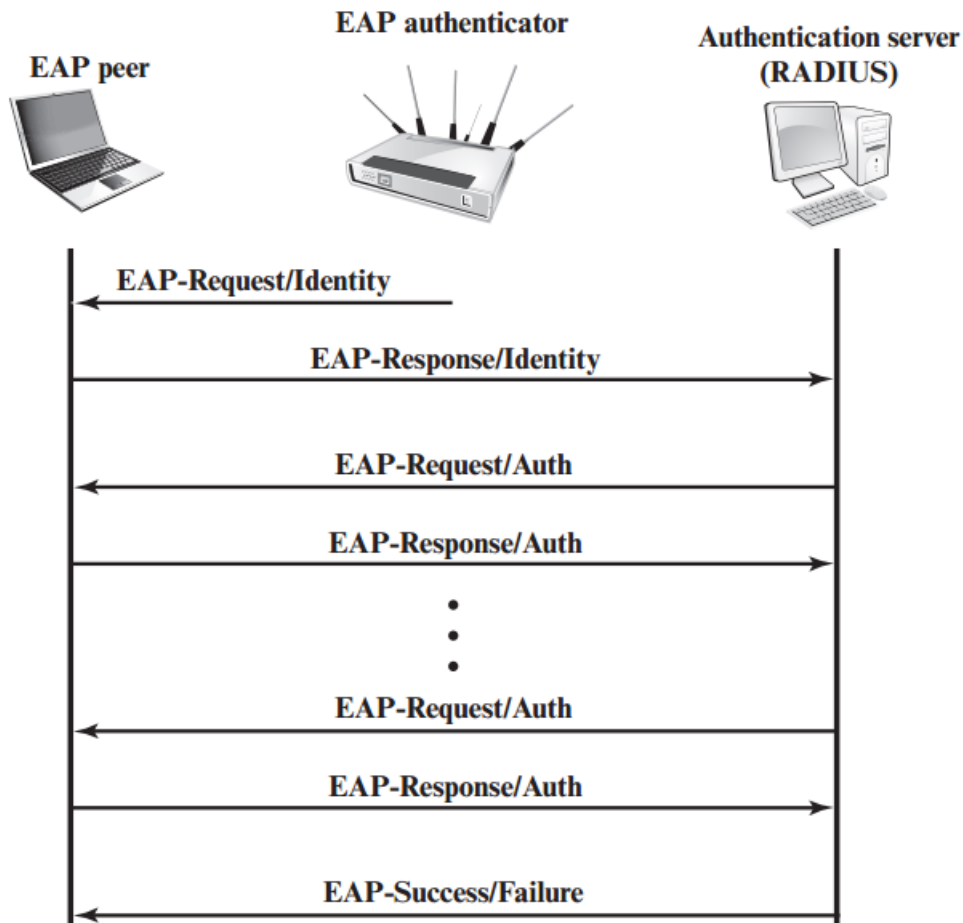


- ◆ **EAP peer:** клиентско устройство опитващо се да получи достъп до мрежата
- ◆ **EAP authenticator:** точка на достъп или NAS, които изискват EAP автентикация преди да разрешат достъпа до мрежата;
- ◆ **Authentication server:** Сървър, който валидира данните удостоверяващи клиента и оторизира достъпа до мрежата. Обикновено това е RADIUS сървър.

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Обмен на съобщения при EAP (RFC 3748)



◆ EAP съобщенията имат следните полета:

- ✓ **Code**: определя типа на съобщението: Request (1); Response (2); Success (3); Failure (4)
- ✓ **Identifier**: използва се за съответствие на отговорите със заявките. Стойността му се увеличава при изпращане на всяко следващо съобщение. Идентификатора в отговора е равен на този в заявката.

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Формат на съобщения при EAP

Code	Identifier	Length	[Type]	Data
8b	8b	16b	8b	

✓ **Length:** дължина на EAP съобщението (в октети), включително полетата Code, Identifier, Length, Type, Data

✓ **Type:** указва начина на автентикация, според дефиницията на IANA.

- 1 = Identity
- 2 = Notification
- 3 = NAK, валиден само при отговорите
- 4 = MD5 Challenge (CHAP)
- 5 = One time password
- 6 = Generic Token card (GTC)
- 254 = Expanded types

✓ **Data:** Съдържа информация свързана с автентикацията

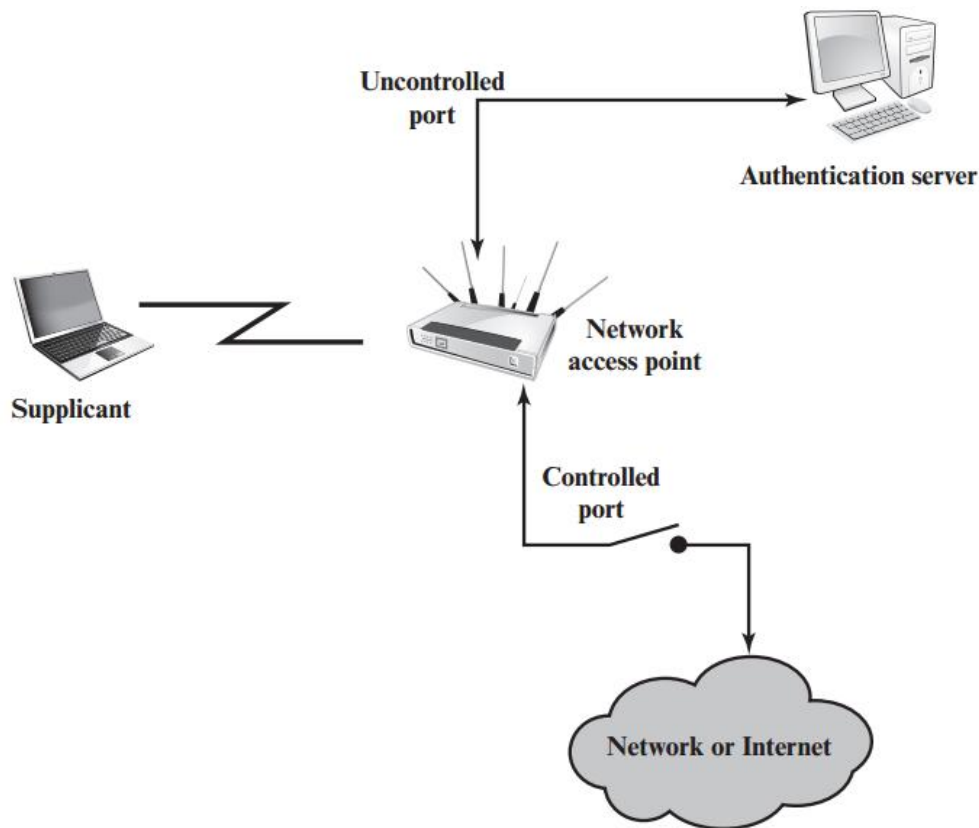
✓ Съобщенията **Success** и **Failure** нямат поле **Data**

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Автентикация на база на порт чрез IEEE 802.1X



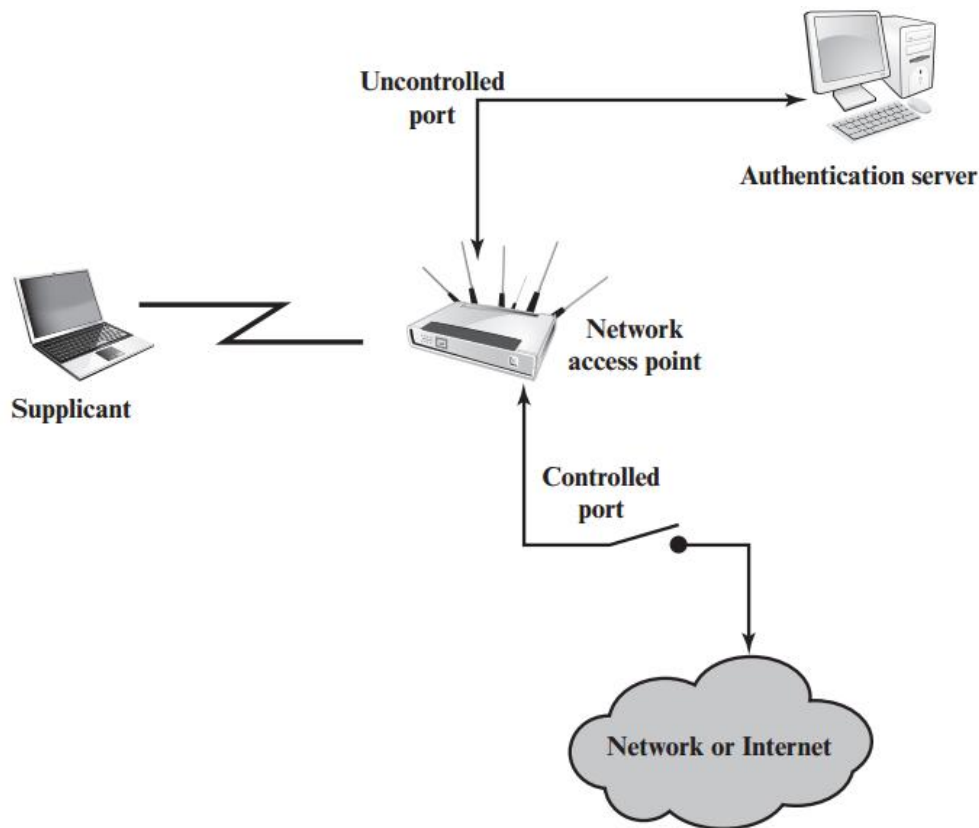
◆ Терминология

- ✓ Supplicant (EAP peer)
- ✓ Authenticator
- ✓ Authentication exchange
- ✓ Authentication process
- ✓ Authentication server (EAP AS)
- ✓ Authentication transport
- ✓ Bridge port
- ✓ Edge port
- ✓ Network access port (EAP authenticator)
- ✓ Port access entity (PAE)

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Автентикация на база на порт чрез IEEE 802.1X



◆ EAPOL (EAP over LAN)

Видове кадри:

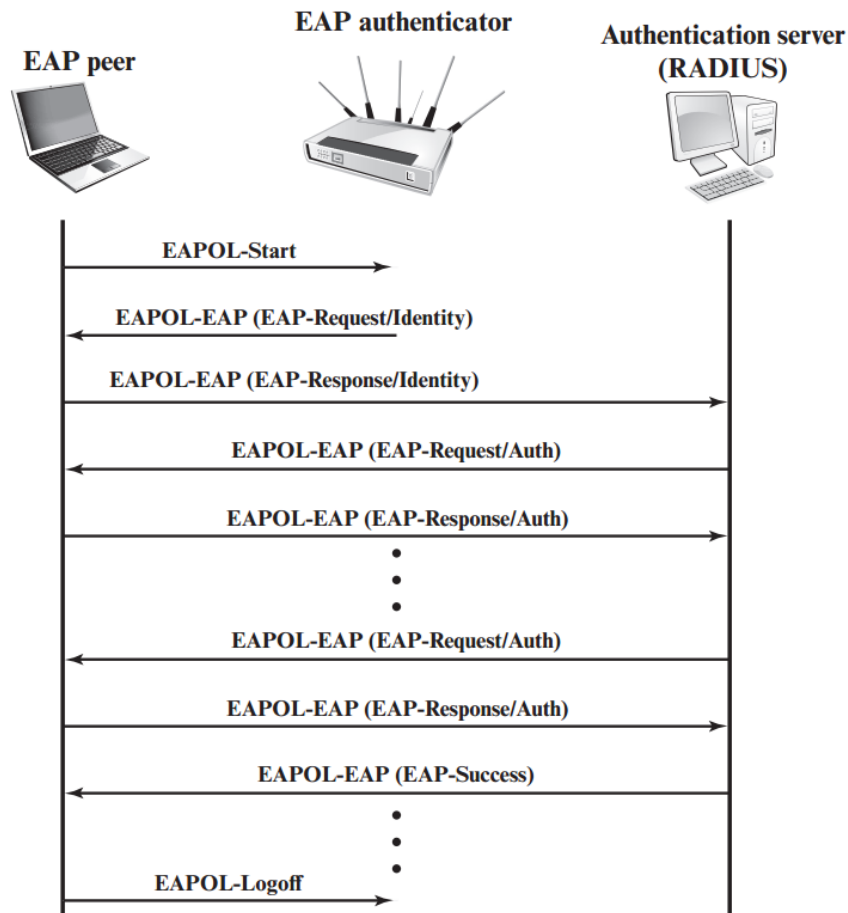
- ✓ EAPOL-EAP – съдържа капсулиран EAP пакет
- ✓ EAPOL-Start – пакет, с който клиентът търси автентикатор
- ✓ EAPOL-Logoff – пакет, с който клиентът заявява желание да бъде изключен от мрежата
- ✓ EAPOL-Key – пакет, с който се изпращат сесийните ключове към клиента когато решението е да му се даде достъп

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Пример за автентикация чрез IEEE 802.1X с RADIUS

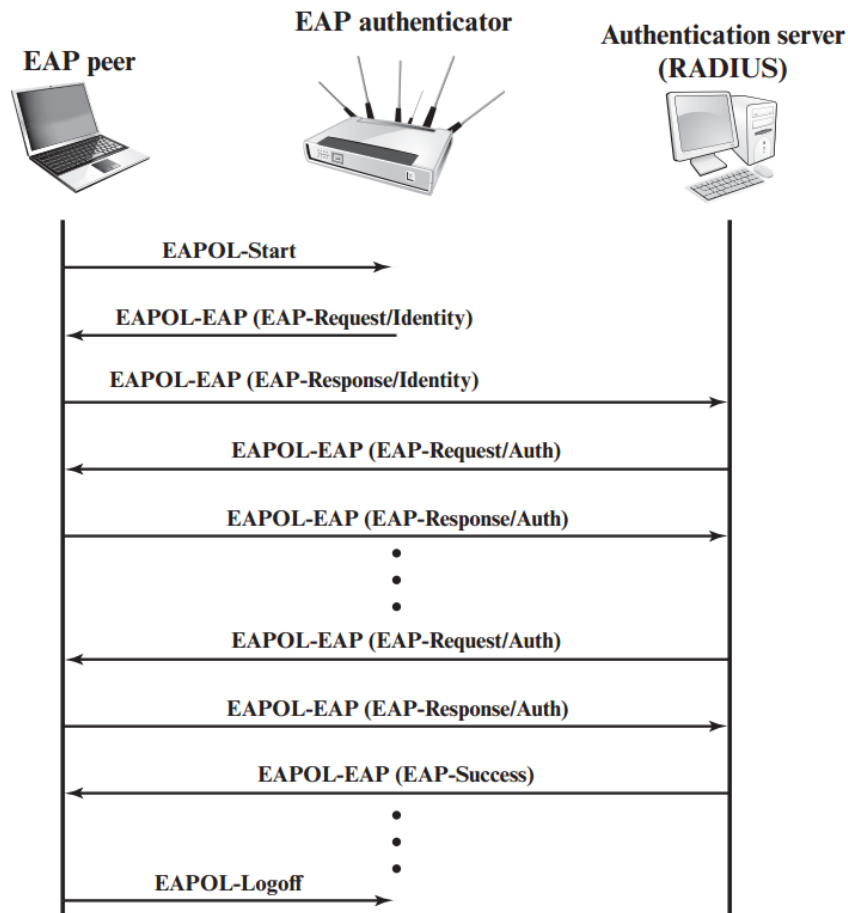


1. EAPOL-Start изпратено като мултикаст до 01:80:c2:00:00:03
2. EAP-Request/Identity кадър, изпратен от автентикатора, с който иска да му бъдат предоставени данни за идентификация, например – име. Автентикаторът изпраща такова съобщение периодично дори преди да е получил EAPOL-Start;
3. Клиентът изпраща исканите данни отговаряйки с EAP-Response/Identity кадър, който автентикатора получава чрез неконтролиран порт. Той се капсулира в RADIUS over EAP пакет и се изпраща до RADIUS сървър, като Radius-Access-Request пакет;
4. RADIUS (AAA) сървър отговаря с Radius-Access-Challenge пакет, който се изпраща чрез автентикатора към клиента като EAP-Request и съдържа информация за предизвикателството (challenge), напр. парола, и за метода на автентикация, който ще се използва в по-нататъшната комуникация. Ако клиентът не поддържа предложения метод на автентикация

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

➤ Пример за автентикация чрез IEEE 802.1X с RADIUS



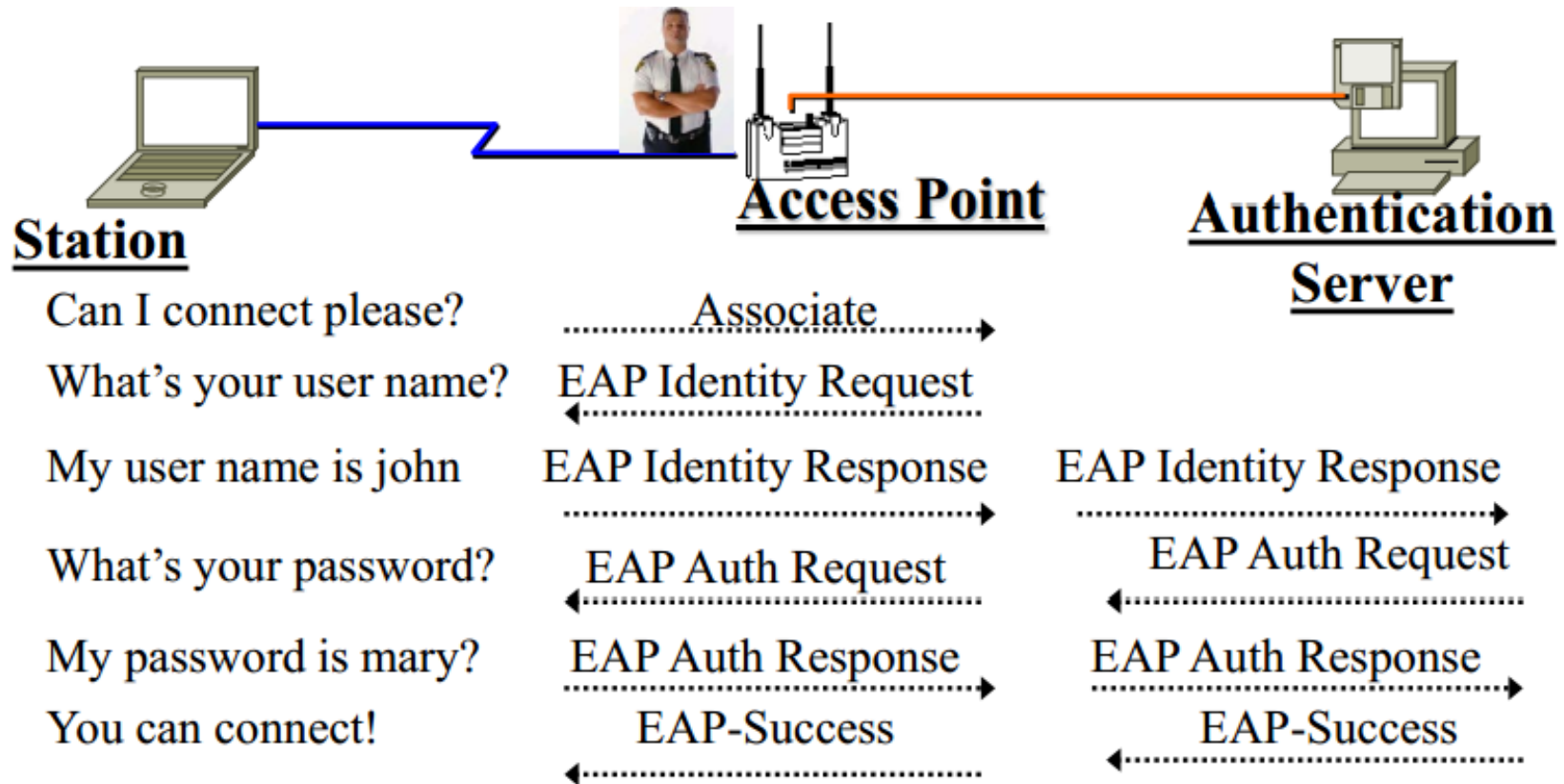
заявява искане за друг метод изпращайки EAP-Response Auth NAK указвайки желаният метод за автентикация. Автентикаторът препраща съобщението към AS;

5. AS изпраща наново Radius-Access-Challenge базирано на EAP authentication method заявен от клиента.;
6. Клиентът формира EAP-Response, като в автентикатора се формира Radius-Access-Request с отговор на предизвикателството. След като метода за автентикация е потвърден следва обмен на няколко съобщения;
7. RADIUS (AAA) сървър дава достъп с Radius-Access-Accept съобщение. Автентикатора издава EAP-Success пакет. Контролираният порт е оторизиран и клиентът може да осъществи достъп до мрежата. Ако предоставените от клиента данни за автентикация не са правилни, AS изпраща Radius-Access-Reject съобщение;

МРЕЖОВО АДМИНИСТРИРАНЕ

Методи за осигуряване на достъп до мрежата

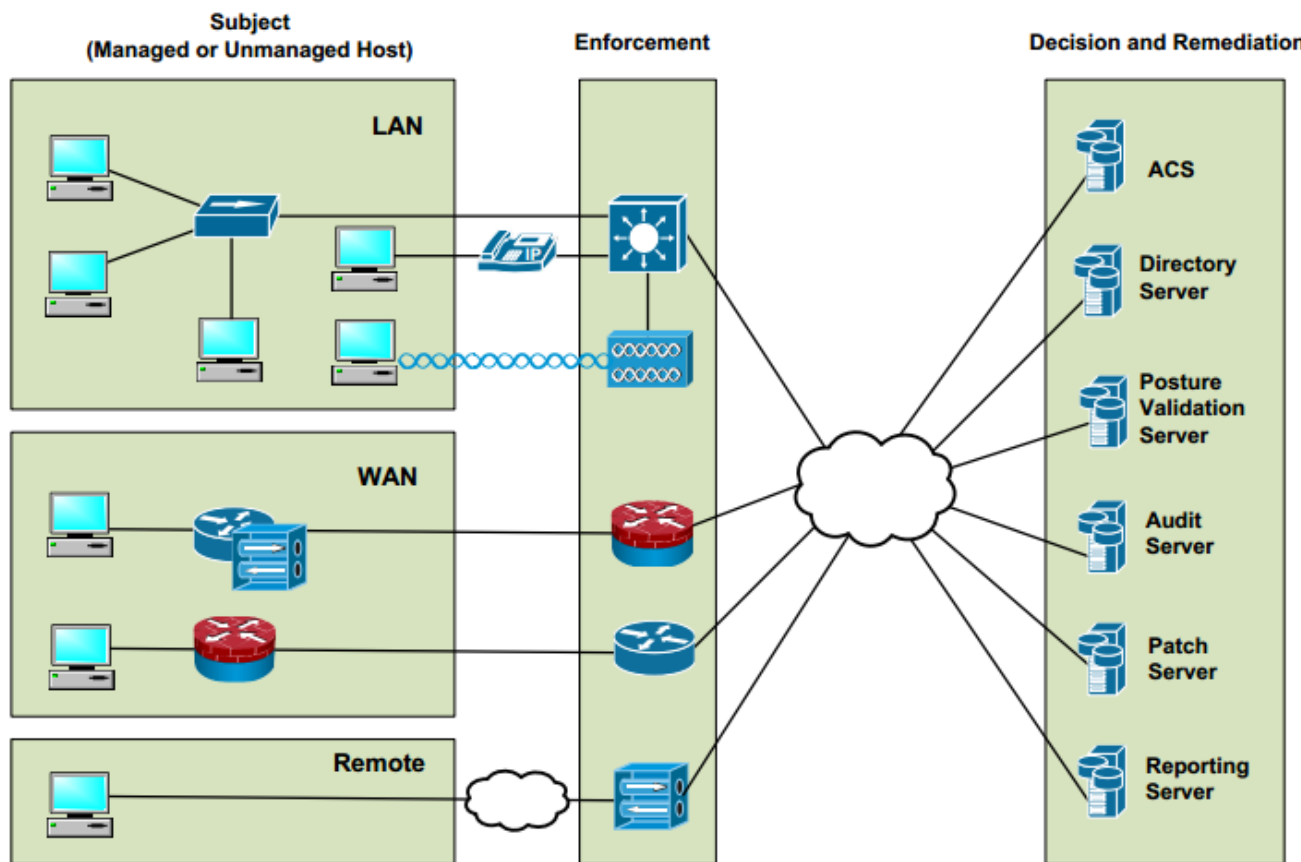
➤ Пример за автентикация чрез IEEE 802.1X



МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Cisco (Cisco identity services engine)

- NAC Framework оценява състоянието на хостовете с цел да предотврати достъпа до мрежата на неоторизирани или уязвими крайни точки.



Субекти (Subjects):

Това са управляеми или неуправляеми хостове, които имат достъп до мрежата в която се изпълнява NAC.

Изпълнителни устройства

(Enforcement devices):

Това се мрежови устройства, действащи като точки за прилагане на правилата на NAC.

Устройства за решаване и възстановяване

(Decision and remediation devices):

В тази група много и различни мрежови устройства поддържат NAC рамковата архитектура:

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Cisco

- **Authentication, authorization, and accounting (AAA) server:** Това е централният сървър за политика, който обобщава едно или няколко удостоверявания и разрешения в едно решение, което записва в мрежовия профайлер за изпълнение от мрежовите устройства за достъп. Сървърът AAA на Cisco, който поддържа NAC, се нарича Cisco Secure Access Control Server (ACS);
- **Директориен сървър (Directory server):** Това е централният директориен сървър, който удостоверява самоличността на потребителя или машината. Като примери тук можем да дадем Microsoft Active Directory, Novell Directory Services (NDS), и сървърите за еднократни пароли;
- **Сървър за валидиране на състоянието (Posture validation server - PVS):** Този сървър действа като точка за взимане на решения в зависимост от конкретната политика в NAC.

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Cisco

В зависимост от възприетата политика той определя набора от необходимите идентификационни данни. Като примери можем да посочим антивирусните сървъри и сървърите за сигурни приложения.

- **Сървър за възстановяване (Remediation server):** В него се прилагат управляващите решения за привеждане на несъответстващите хостове в съответствие. Това може да става със специализирани приложения за управление на пачовете или просто това да е уеб сайт за разпространение на софтуер;
- **Сървър за одит (Audit server):** Това е сървър или софтуер, който извършва оценка на уязвимостта на хоста за да определи неговото ниво на съответствие или риск преди допускането му до мрежата;

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Cisco

- **Поддръжка на NAC Framework от маршрутизаторите**
- Механизмът на IP NAC в слой 3 използва протоколите EAP и UDP. Маршрутизаторите които поддържат този механизъм се разглеждат като устройства от типа NAC Release 1.0. Те могат да действат като система предотвратяваща проникването в мрежата (NIPS). Такива устройства се появиха за първи път в средата на 2004 година и бяха включени в операционната система Cisco IOS Software Release 12.3(8)T. Тогава бяха въведени защитните стени, NIPS и криптографската поддръжка.
- Хостове без агенти на NAC (NAC Agentless Host - NAH) е друг механизъм на NAC, който позволява достъп до мрежата на хостове, които не могат да бъдат привеждани в съответствие с NAC. Към тази категория принадлежат принтерите, скенерите, фотокопирните машини, камерите, сензорите и

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Cisco

➤ Поддръжка на NAC Framework от маршрутизаторите

специализираното оборудване. Тук попадат също компютрите с неподдържани операционни системи, с вградените операционни системи, както и персоналните защитни стени. За тях могат да бъдат конфигуриране статични изключения, които да позволяват заобикалянето на процеса на валидиране на състоянието за отделни MAC и IP адреси.

- Устройствата, които поддържат или механизма на IP NAC в слой 2 (протоколи EAP и UDP) или NAC 802.1X в слой 2 (протоколи EAP и 802.1X), се смятат за устройства от типа NAC Release 2.0. Механизмът IP NAC в слой 2 се задейства от появата на ARP или евентуално DHCP трафик в интерфейса на комутатора.

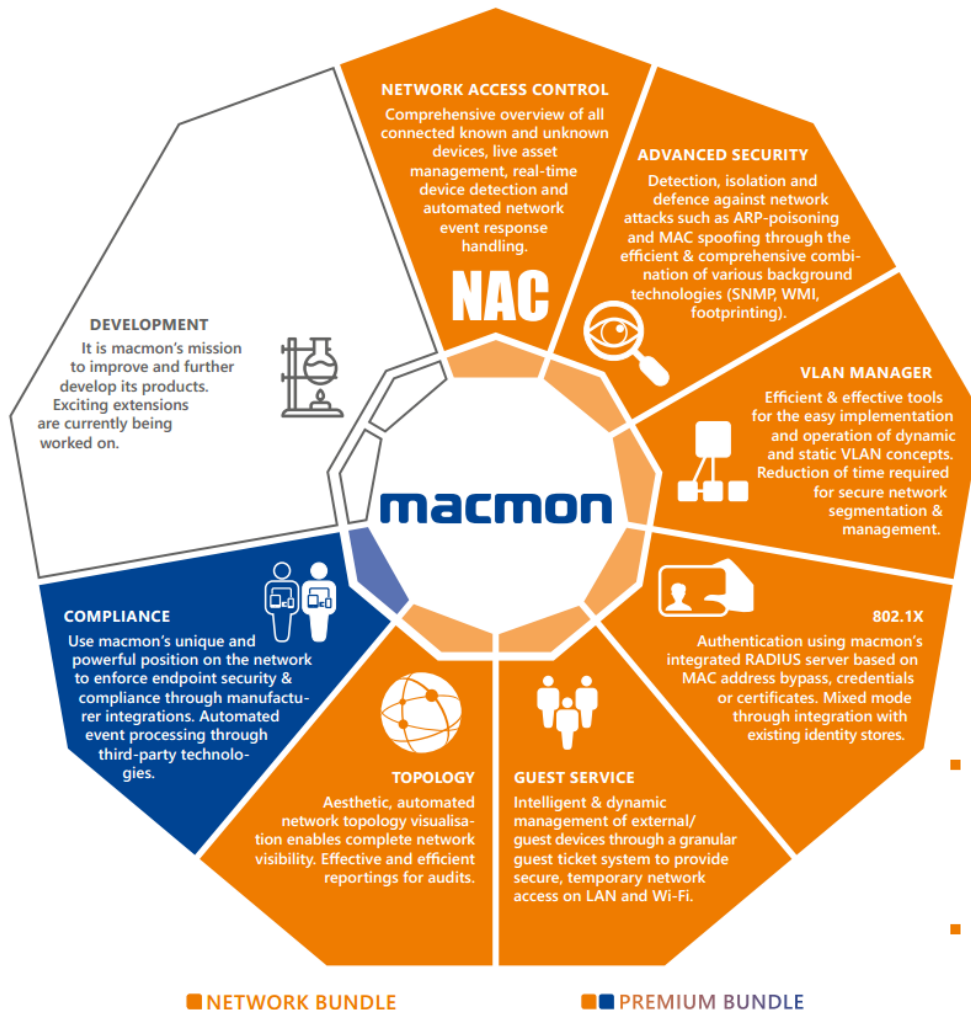
МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Cisco

- **Поддръжка на NAC Framework от комутаторите**
- NAC извършва валидиране на състоянието на слой 2 за хостовете с или без разрешен 802.1X. Уязвимите и несъответстващи хостове могат да бъдат изолирани, като получат непълен, намален достъп до мрежата, или пренасочени към сървърите за възстановяване в зависимост от организационната политика.

МРЕЖОВО АДМИНИСТРИРАНЕ

Пример за NAC Framework от Macmon



- **Network Bundle**
macmon NAC, Advanced Security, VLAN Manager, Guest Service, 802.1X, Topology
- **Premium Bundle**
Modules of Network Bundle + extensive mechanisms to proof the compliance/security status of end devices

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Други решения за NAC

- Aruba ClearPass от HPE
- FortNAC от Fortinet
- Secure Mobile Access от SonicWall
- Huawei NAC
-

МРЕЖОВО АДМИНИСТРИРАНЕ

БЛАГОДАРЯ ЗА ВНИМАНИЕТО!

доц. д-р инж. Росен Радков